PRODUCT REQUIREMENT DOCUMENT (PRD)

UMHackathon 2026

umhackathon@um.edu.my

© UMHackathon 2026

Email: umhackathon@um.edu.my

Table of Contents

1. Project Overview 1
2. Background & Business Objective 1
3. Product Purpose 2
4. System Functionalities 2
5. User Stories & Use Cases 3
6. Features Included (Scope Definition) 3
7. Features Not Included (Scope Control) 3
8. Assumptions & Constraints 4
9. Risks & Questions Throughout Development 4

© UMHackathon 2026

Email: umhackathon@um.edu.my

Project Name: LexiFlow AI

Version: 2.0

1. Project Overview

- **Problem Statement:** Organizations face challenges in preventing human-error-driven data leaks, especially when employees share sensitive information through emails and digital communication tools. Current solutions rely heavily on manual compliance checks or post-incident auditing, which fail to prevent data leakage in real time.
- **Target Domain:** AI-driven real-time compliance enforcement system for enterprise communication platform, focusing on email security, data protection and regulatory compliance such as PDPA and GDPR during day-to-day operations.
- **Proposed Solution Summary:** LexiFlow AI is an intelligent compliance enforcement system that consists of an AI compliance plugin and a centralized web dashboard. It integrates across enterprise systems (email, chat, documents, file sharing, and APIs) to automatically detect, block and log sensitive data exposure in real time. It removes manual scanning entirely and acts as an always-on AI compliance layer that prevents violations before they occur.

2. Background & Business Objective

- **Background of the Problem:** Modern organisations operate across fragmented systems such as Gmail, Slack/Teams, Google Drive, CRM tools, and internal databases. Sensitive data flows freely between these systems. Traditional security tools are siloed, focusing only on specific channels (e.g., email DLP), leaving gaps where data can still leak through chat apps, file uploads, or copy-paste actions.

© UMHackathon 2026
Email: umhackathon@um.edu.my

- **Importance of Solving This Issue:** Preventing data leaks at the point of transmission significantly reduces legal risk, financial penalties and reputational damage. In Malaysia, under the Personal Data Protection Act (PDPA), organizations can face fines up to RM1,000,000 and/or imprisonment up to 3 years for serious non-compliance, including improper handling or unauthorized disclosure of personal data. Additional offences such as failure to protect or report breaches can result in penalties ranging from RM250,000 to RM500,000, along with potential jail terms.
- **Strategic Fit / Impact:** LexiFlow AI aligns with the future of AI-native enterprise security architecture, enabling organizations to implement a single compliance layer across all productivity tools.

3. Product Purpose

3.1. Main Goal of the System: To provide an always-on AI compliance enforcement layer that automatically governs all data flows and prevents sensitive data leaks in enterprise communication systems.

3.2. Intended Users (Target Audience):

- Enterprise Compliance Officers
- CTOs/ CIOs
- Security & Risk Management Teams
- IT Administrators
- Organization Operations Teams
- Product & Engineering Teams

4. System Functionalities

4.1. Description: LexiFlow AI is an intelligent compliance enforcement system operated as a cross-platform real-time data governance engine that integrates with enterprise tools and

monitors all outgoing and internal data movement. It continuously analyzes structured and unstructured data flows and enforces compliance policies automatically before data leaves a system boundary.

4.2. Key Functionalities:

- **AI Compliance Reasoning Engine:** Interprets unstructured contents such as email and documents, applies PDPA rules to real situations, and performs multi-step contextual reasoning.
- **Personal Data & Sensitive Information Detection:** Recognizes contextual sensitive data and flags potential data privacy risk under PDPA compliance rules.
- **Automated Compliance Decision System:** Classifies decisions (Safe/ Warning/ Blocked) to reduce manual review by compliance officers through instant checks.
- **Real-time Risk & DPIA Assessment:** Perform instant DPIA when sensitive data is detected, and provides risk scoring and severity level in real time.
- **Explainable & Auditable AI System**: Provides clear explanations for every decision made, and maintain a full audit trail of actions, decisions and reasoning steps

4.3. AI Model & Prompt Design

4.3.1. Model Selection: Uses Z.AI GLM (General Language Model) due to strong contextual understanding across structured and unstructured data, ability to classify multi-source enterprise content and high performance in multi-step reasoning for compliance enforcement.

4.3.2. **Prompting Strategy:** LexiFlow AI adopts a multi-step agentic prompting strategy combined with structured few-shot examples.

- Step 1: Intent Detection Prompt
  Identifies whether content contains personal data, sensitive information, or compliance risk.

- Step 2: Policy Reasoning Prompt
  Applies compliance rules (e.g., PDPA definitions, company policies) to evaluate risk level.
- Step 3: Action Decision Prompt
  Determines system action such as *allow, warn, redact, or block*.

This strategy is chosen because compliance evaluation requires layered reasoning rather than single-step classification. A purely zero-shot approach is insufficient due to the ambiguity of enterprise communication. The multi-step agentic structure improves accuracy, interpretability, and auditability, which are key requirements for regulatory environments.

4.3.3. **Context & Input Handling**: LexiFlow AI is designed to handle large-scale unstructured inputs such as long emails, documents, and chat threads.

- Maximum input limit: ~32,000 tokens per request (GLM context window constraint)
- If input ≤ limit: processed directly by GLM
- If input exceeds limit:
  - System performs semantic chunking (splitting by meaning, not fixed length)
  - Each chunk is processed individually
  - A final aggregation step summarizes risk across all chunks
- If input is excessively large or malformed:
  - System triggers rejection with warning
  - Logs event in audit dashboard for traceability

This ensures no sensitive content is missed even in long enterprise documents while maintaining performance efficiency.

4.3.4. **Fallback & Failure Behavior:** If the AI model produces low-confidence results, ambiguous classification, or system failure:

- The system automatically switches to REQUIRE REVIEW mode
- The content is flagged and sent to the Admin Audit Dashboard

© UMHackathon 2026

- A compliance officer or admin must manually review the case before any action is taken

This fallback mechanism ensures zero-risk tolerance for compliance decisions, prioritizing safety and regulatory accountability over automation when uncertainty is detected.

5. User Stories & Use Cases

- **User Stories:**
  - *"As a compliance officer, I want all company data movements monitored so that no sensitive information leaves the organization without approval."*
  - *"As an IT admin, I want to block risky file transfers automatically so that employees cannot accidentally leak data."*
- **Use Cases (Main Interactions):**

  Real-Time Data Monitoring & Risk Detection

  The system monitors user activities across enterprise tools (e.g., email, file sharing, messaging platforms) in real time.

  Flow:

  1. The user performs an action (send email, upload file, share document).
  2. LexiFlow AI intercepts and processes the content.
  3. GLM-based reasoning engine analyzes unstructured and structured data.
  4. The system identifies sensitive information (e.g., personal data, financial data, identifiers).
  5. Compliance policy engine evaluates risk level.
  6. System classifies outcome:
     - Low Risk → Allow
     - Medium Risk → Warn user
     - High Risk → Block action

© UMHackathon 2026

Policy-Based Compliance Enforcement Flow

LexiFlow AI applies configurable compliance rules to determine whether a user action is permitted.

Flow:

1. Admin defines compliance policies (e.g., PDPA, internal company rules).
2. User initiates data-related action.
3. System retrieves relevant policy rules.
4. AI performs contextual reasoning using GLM.
5. Decision engine evaluates compliance violation risk.
6. System executes corresponding action:
    - Approve action
    - Request modification (e.g., redact sensitive content)

Audit Logging & Administrative Review

All system decisions are recorded for transparency, accountability, and compliance auditing.

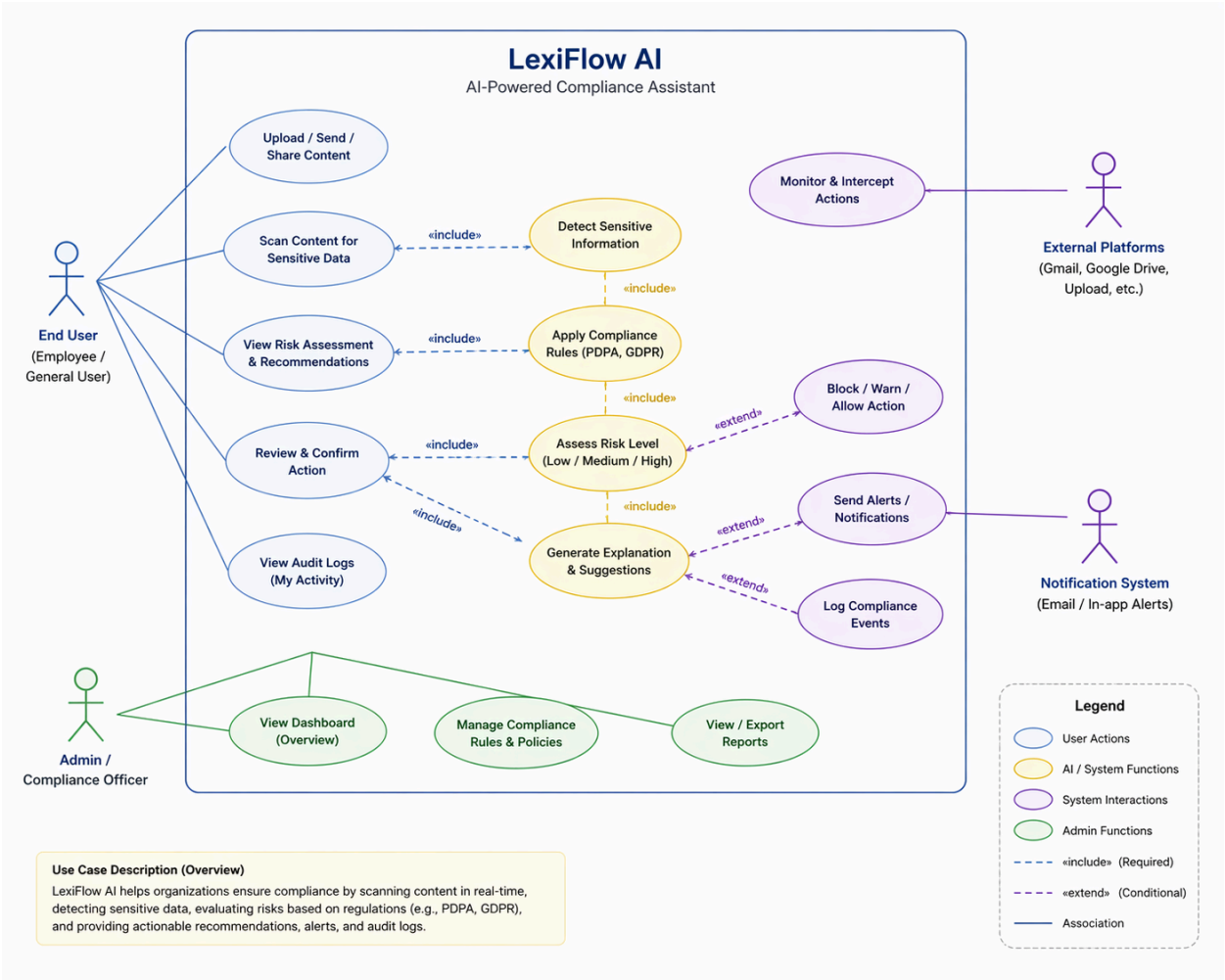
Flow:

1. Every user action is logged (allowed, modified, or blocked).
2. Logs include:
    - User identity
    - Action type
    - Detected sensitive data
    - Risk classification
    - System decision

© UMHackathon 2026
Email: umhackathon@um.edu.my

3. Admin dashboard provides visualization of:
    - Risk trends
    - Policy violations
    - User-level activity tracking
4. Compliance officers may override decisions if required.

- **Use Case Diagram:**



© UMHackathon 2026
Email: umhackathon@um.edu.my

6. Features Included (Scope Definition)

- Automatically scans emails, documents, and uploads (e.g., Google Drive, Gmail) to detect personal and sensitive data
- Applies PDPA/GDPR rules with contextual understanding (not just keyword matching) to assess risk levels.
- Classifies actions into Low / Medium / High risk and provides real-time warnings, suggestions, or blocking.
- Tracks and records all user actions, AI decisions, and compliance outcomes for monitoring and reporting.
- Simulates integration with platforms like Google Drive and Gmail for demo purposes.

7. Features Not Included (Scope Control)

- Limited integration and simulation with Google, Microsoft Teams, Slack and other APIs.
- System does not include full-scale backend service, storage systems or production-ready architecture.
- Limited support for complex file formats (e.g., encrypted files, large datasets, images with OCR not fully implemented).
- Model does not automatically retrain on user data due to privacy and security constraints.

8. Assumptions & Constraints

- **LLM Cost Constraint:** Each user session (e.g., scanning an email or document) is estimated to use ~1,000–3,000 tokens, depending on content length and complexity. High usage at scale can significantly increase operational costs.
- **Technical Constraints:** LexiFlow AI operates primarily as a browser extension + web dashboard, integrating with platforms like Google Drive and Gmail. Limited access to

© UMHackathon 2026

deep platform APIs (e.g., real-time interception may be restricted) and cannot fully modify native platform behavior.

- **Performance Constraints:** Real-time compliance checking is expected during actions like file upload or email sending. While large files such as PDF and datasets require high processing time and tokens.
- **User Input:** The AI system is designed as a decision-support tool, not a fully autonomous system. It may not always be 100% accurate.

9. Risks & Questions Throughout Development

- **AI Decision Accuracy:** How do we ensure the AI correctly identifies sensitive data and applies compliance rules?
- **Data Privacy and Security:** How do we ensure user data is not exposed during AI processing such as sending to external APIs?
- **Compliance Rule Updates:** How do we keep up with changing regulations (PDPA, GDPR, etc.)?

© UMHackathon 2026